

Source and scope

Publication approval

Findings

```
- **Finding ID:** 444d15b0eae2ba3720852d84136753351fb94e180d7313056d0ef9aff96d88c2  
- **Severity:** high  
- **Anchor:** DnsMessageParser struct and get\_rdata\_decoder\_with\_raw\_message method  
- **Severity rationale:** adversarial: Résumé café π with a long URL  
https://example\invalidabcdefghijklmnpqrstuvwxyx0123456789abcdefghijklmnopqrstuvwxyz0123456789abcdefghijklmnop
```

[illegible]

- ****Disagreement:**** none recorded
- ****Scope limits and uncertainty:****
- adversarial: Analysis is limited to the provided code and does not include all call sites of the DNS parser which may influence exploitability\.

****Citations****

```
- `lib/dnsmsg-parser/src/dns_message.rs` at source object `fd0cc8f613dcfa867dd088ef9f09c65a11eb0013`;
evidence `a993dc62a8392670ae6667bb1a4bf994b0a57343f958a3d9bd36f16a78b10573`; content `
8cf178237232852f48ba40b476ae0555256495f70bf0d9f0ef81bcd79673f53d`
```

****Attributed source assessments****

- ****adversarial / adversarial\raw_message_for_rdata_parsing_reuse_mutation**** — Résumé café π with a long URL
https://example\invalid\abcdefghijklmnopqrstuvwxy0123456789abcdefghijklmnopqrstuvwxy0123456789abcdefghijklmnopqrstuvwxy0123456789 and wide token

[illegible]

- **Dependencies:** none
- **Owner role:** repository\owner
- **Assignment:** unassigned
- **Relevant paths:**
- lib/dnsmsg\parser/src/dns_message.rs
- **Acceptance criteria:**
- Resolve synthesized finding 444d15b0eae2ba3720852d84136753351fb94e180d7313056d0ef9aff96d88c2 without changing unrelated scope\.
- Retain traceability to evidence ids: a993dc62a8392670ae6667bb1a4bf994b0a57343f958a3d9bd36f16a78b10573\.
- Add or update focused validation proving the bounded repair and negative case\.
- **Validation:**
- Run the smallest focused test covering the repaired path\.
- Run git diff \-\-check over the exact candidate\.
- Independent reviewer must verify finding 444d15b0eae2ba3720852d84136753351fb94e180d7313056d0ef9aff96d88c2 is resolved and no unrelated finding was bundled\.
- **Risk, non-goals and uncertainty:**
- Do not create issues, assign humans, publish PRs, or mutate source as part of planning\.
- Do not combine unrelated findings merely because they share severity\.
- Preserve scope limits: adversarial: Analysis is limited to the provided code and does not include all call sites of the DNS parser which may influence exploitability\.
- **Additional uncertainty:**
- adversarial: Analysis is limited to the provided code and does not include all call sites of the DNS parser which may influence exploitability\.

Test plan

- **Test:** Focused regression test: Possible mutation of raw message buffer in DNS message parser to evade detection or cause inconsistent parsing
- **Test ID:** a472cd3de2805de44d9bae9e5df2da39355088a5ebe64ee264ccc74ddf0f0681
- **Finding ID:** 444d15b0eae2ba3720852d84136753351fb94e180d7313056d0ef9aff96d88c2
- **Severity:** high
- **Source finding IDs:**
- 65417167b20837b21e97cec196683f68b6ae88a7b8d7067f1306ef7c153933d2
- **Source evidence:**
- a993dc62a8392670ae6667bb1a4bf994b0a57343f958a3d9bd36f16a78b10573
- **Behavior under test:** Verify \lib\dnsmsg\parser/src/dns_message_parser.rs\ keeps DNS RDATA name decoding isolated per message: repeated \DnsMessageParser::get_rdata_decoder_with_raw_message\ calls must not reuse or cumulatively extend \raw_message_for_rdata_parsing\ with unrelated attacker-controlled raw RDATA from a prior call\.
- **Proposed location:** lib/dnsmsg\parser/src/dns_message_parser.rs
- **Fixture:** In \lib\dnsmsg\parser/src/dns_message_parser.rs\ 's existing \#[cfg(test)] mod tests\, add \test_compressed_rdata_buffer_is_replaced_between_calls\. Decode the existing MINFO message \5ZWBgAABAAEAAAABm1pbmZvbwhleGFtcGxIMQNjb20AAA4AAcAMAA4AAQAADGsADQRmcmVkwBMDam9lwBMAACkQAAAAAAAAHAAKABgZ5zwJEK3VJQEAAABfSBqpS2bKf9CNBXg=\ and first RDATA \BGZyZWTAEWnqb2XAEw==\; on the same parser, then pass a second MINFO \NULL\ payload \b"\x05alice\x07example\x03com\x00\x03bob\x07example\x03com\x00"\. Assert the first result is \fred.example1.com. joe.example1.com.\, the second is \alice.example.com. bob.example.com.\, and the retained buffer length equals \parser.raw_message\().len\()\ + second_rdata.len\()\ rather than both RDATA payloads cumulatively\.

- **Expected pre-fix failure:** Before the fix, the second same\-parser MINFO decode starts at the original message boundary but reads the first appended RDATA, yielding `\fred.example1.com.\ joe.example1.com.\` instead of the second payload's `\alice.example.com.\ bob.example.com.\`; the retained buffer also includes both RDATA payloads.
- **Expected post-fix assertion:** After the fix, the first MINFO result equals `\fred.example1.com.\ joe.example1.com.\`, the second equals `\alice.example.com.\ bob.example.com.\`, and `\raw_message_for_rdata_parsing().unwrap().len()` equals `\raw_message().len() + second_rdata.len()`; any prior\-call influence fails one of those exact assertions.
- **Validation lane:** PVF local focused validation plus git diff \-check
- **Resource profile:** local deterministic CPU/filesystem; no provider credentials, network, source mutation, or paid infrastructure
- **Detection rationale:** Targets finding `444d15b0eae2ba3720852d84136753351fb94e180d7313056d0ef9aff96d88c2` by exercising `\lib\dnsmsg\parser/src/dns_message_parser.rs` through the exact state\reuse risk described in the accepted synthesis: same parser, multiple decode calls, attacker\controlled raw RDATA, and an assertion that prior\call bytes cannot affect the later decode.
- **Test non-goals:**
 - Do not implement the production repair in the test\plan step.
 - Do not mirror the implementation by asserting only function names or snapshot text.
 - Do not mutate repository source while generating the plan.
- **Test scope limits:**
 - adversarial: Analysis is limited to the provided code and does not include all call sites of the DNS parser which may influence exploitability.

Output boundary

This is the canonical local PDF rendering of the approved review. It does not claim HTML, Markdown, remote, or customer publication.